

SIT 218/738: Secure coding

Distinction task 4.3D: Develop your own injection attack preventions using hibernate validator

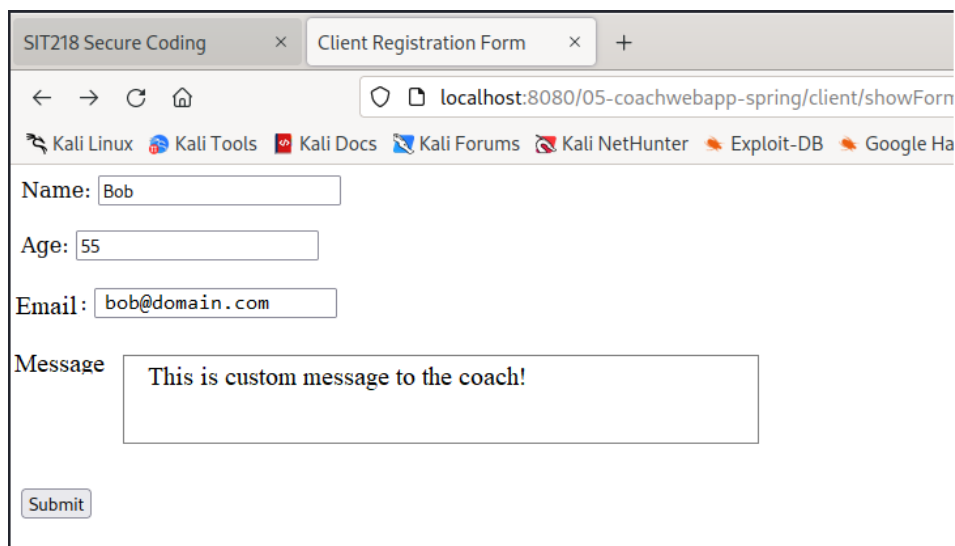
Objective

Input validations is an important function to prevent many forms of web application attacks. But various business requirements or application functionalities can make input validations a complex task. Particularly when you need to provide functionalities for users to enter comments or fields that accepts special characters. In this task you will modify an existing web application by adding more input fields and develop correct validation mechanisms to prevent injection attacks. Furthermore, input validations can be applied both at the client-side or server-side. Client-side validations use HTML code to validate user input and are done on the client's browser saving server resources. However, secure application incorporates both client-side and server-side validations to secure the web application. In this task you will incorporate both the client-side and server-side input validations.

Overview

In the previous task, we implemented the regex pattern to prevent users from entering the scripts or tagged input values in the format '<>' for 05-coachwebapp-spring web app. This prevented many of the XSS attack input patterns.

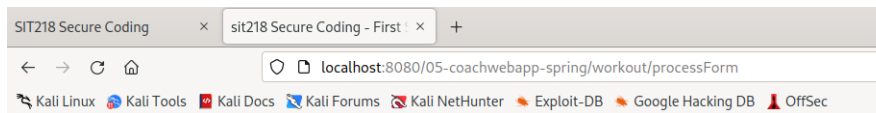
Now add two additional input fields to the web app that asks user to enter their email address and a text area that allows users to send a custom request to the coach.



The screenshot shows a web browser window with the title 'SIT218 Secure Coding' and a tab 'Client Registration Form'. The address bar shows 'localhost:8080/05-coachwebapp-spring/client/showForm'. The browser's toolbar includes links to 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Ha'. The form itself has the following fields:

- Name:
- Age:
- Email:
- Message:
- Submit:

When the user clicks the Submit button, the email address and user's message should be displayed as shown below:



Bob, please, run for 30 min

Your message "This is a custom message to the coach!" was received and you will be contacted via your email: bob@doamin.com for further information.

Add the correct input validations with regular expressions to prevent any XSS attack both at the clients-side and server-side. The email address should contain appropriate characters such as '@' and '.com' but other special characters should be blocked. The text area should contain only maximum 200 characters and allow common special characters like (!@#*).

Use this <https://www.geeksforgeeks.org/spring-mvc-textarea/> as reference for adding the text area to the spring app. Use this https://developer.mozilla.org/en-US/docs/Learn/Forms/Form_validation for client-side html validations.

Submission Requirements:

Submit one PDF file containing the following information:

1. The correct regex pattern that blocks these injected data in all the fields
2. Screenshot of the updated app that shows the web app is working correctly and blocking unexpected characters as mentioned in the task description.
3. Updated Client.java code added to the submission document.
4. Updated CoachController.java code added to the submission document.
5. Updated HTML code which includes client validations added to the submission document.

Submission Due

The due for each task has been stated via its OnTrack task information dashboard.